

ApexNova Technologies

Information Security Incident Management Policy

Document ID: ISO-IMP-2026-001

Version: 1.0

Effective Date: January 22, 2026

Review Date: January 22, 2027

Owner: Alexandra Pierce, CISO

Classification: Internal

1. Purpose

This Information Security Incident Management Policy establishes the framework for identifying, reporting, assessing, responding to, and learning from information security incidents at ApexNova Technologies. This policy ensures consistent and effective handling of security events that could impact the confidentiality, integrity, or availability of information assets, in alignment with ISO/IEC 27001:2022 requirements.

2. Scope

- All employees, contractors, and third parties with access to ApexNova Technologies systems and data
- All information systems, networks, applications, and data repositories
- All security incidents regardless of severity or origin
- Cloud, on-premises, and hybrid environments
- Mobile devices managed through MDM systems

3. Definitions

- **Security Incident:** An event that compromises or threatens information assets
- **Security Event:** A detected occurrence indicating a possible security breach
- **Incident Response Team (IRT):** Cross-functional incident management team
- **SIEM:** Security Information and Event Monitoring system

4. Roles and Responsibilities

CISO – Alexandra Pierce

- Overall accountability for incident management
- Final authority on severity classification
- Executive and board communication

SOC Manager – Priya Raman

- 24/7 security monitoring
- Incident triage and escalation

Incident Responder – Lee Armitage

- Containment and remediation
- Forensic analysis

All Employees

- Immediate reporting of suspected incidents
- Preservation of evidence

5. Incident Severity Classification

CRITICAL (P1)

Complete system outage, active data breach, ransomware

Response: 15 minutes | **Resolution:** 4 hours

HIGH (P2)

Unauthorized access, malware outbreaks, DDoS

Response: 1 hour | **Resolution:** 24 hours

MEDIUM (P3)

Suspicious activity, policy violations

Response: 4 hours | **Resolution:** 72 hours

LOW (P4)

Minor issues, low-risk vulnerabilities

Response: 24 hours | **Resolution:** 5 business days

6. Incident Response Process

- Detection and Reporting
- Triage and Classification
- Containment
- Investigation and Analysis
- Eradication and Recovery
- Post-Incident Review

7. Communication and Escalation

Communication follows defined internal and external escalation paths. All external communications require legal approval.

8. Tools and Systems

- SIEM
- ITSM
- DLP
- IAM
- MDM
- Email Security

9. Metrics and Reporting

- MTTD < 1 hour

- MTTR < 4 hours (P1)
- Closure Rate > 95%

10. Training and Awareness

Mandatory annual training, quarterly drills, and tabletop exercises tracked via LMS.

11. Compliance and Audit

Compliance with ISO 27001:2022, GDPR, and CCPA is reviewed annually.

12. Policy Review

Reviewed annually or following major incidents.

Next Review Date: January 22, 2027

13. Approval and Authorization

Alexandra Pierce

Chief Information Security Officer

Date: January 22, 2026

Jonathan Reeves

Chief Executive Officer

Date: January 22, 2026

ApexNova Technologies – Information Security Incident Management Policy

Document ID: ISO-IMP-2026-001 | Version 1.0 | Classification: Internal